MODULE 01 / 44

Authentification & Utilisateurs

Gérer les comptes, l'authentification JWT, les rôles et la sécurité du compte.

Version	MVP
Phase de la roadmap	Phase 1
Statut actuel	Partiel (environ 70 %)
App Django	users
Rôles concernés	Tous
Dépend de	Aucune

Déjà réalisé dans le dépôt

+ CustomUser UUID, rôles, login/refresh/logout, historique de connexion, /users/me/, permissions par rôle, throttling, tests
+ Web : login, register, cookies httpOnly, dashboard protégé

Fonctionnalités à développer

- Inscription, connexion, déconnexion
- JWT access + refresh avec rotation et blacklist
- Vérification de l'email (lien signé, renvoi du lien)
- Mot de passe oublié : demande, email, confirmation (lien 15 min, usage unique)
- Changement de mot de passe avec révocation des sessions
- Profil : avatar, langue, fuseau horaire, devise, préférences
- Sports et compétitions favoris (lié au module 36)
- Sessions actives : liste et révocation par appareil
- Double authentification (2FA)
- Rôles USER / PREMIUM / MODERATOR / ADMIN et permissions

Backend (Django REST Framework)

Endpoints	POST /auth/register/, /auth/login/, /auth/refresh/, /auth/logout/, /auth/password-reset/, /auth/password-reset/confirm/, /auth/verify-email/ ; GET/PATCH /users/me/ ; GET /users/me/history/ ; POST /users/me/password/
Modèles	CustomUser, Role, LoginHistory (+ AuditLog, TwoFactorDevice à créer)
Tâches Celery	Purge périodique de LoginHistory (users/tasks.py)

Frontend web (Next.js)

/auth/login, /auth/register, /auth/forgot-password, /auth/reset-password, /auth/verify-email, /profile, /settings

Application mobile (Expo / React Native)

Écrans connexion, inscription, mot de passe oublié, profil et paramètres. Tokens dans le stockage sécurisé (SecureStore), jamais en clair.

Tests et critères de validation

- Tests API : inscription, doublon d'email insensible à la casse, rôle non modifiable par l'utilisateur
- Rate limiting (429) sur les routes d'auth
- Jeton de reset à usage unique et expiré après 15 min
- Aucune énumération de comptes sur les routes de reset

Définition de « terminé »

[ ] Modèles et migrations créés, API documentée dans Swagger
[ ] Tests automatisés au vert (python manage.py test)
[ ] Écrans web et mobile branchés sur l'API réelle (aucune donnée en dur)
[ ] Aucune probabilité présentée comme une certitude
[ ] Code poussé sur GitHub et relu